RaceDay - API Endpoint Plan

Module: PROG6212 Programming 2B

Project: RaceDay Event Management System

Part: 1 - System Planning and Database

Date: 2026-04-9

Authentication & Authorization

• None (Public): No authentication required. Anyone can call this endpoint.

• Any (Logged In): User must be authenticated, but any role is accepted

. • Organiser: Only users with Role = 'Organiser' can access.

• Participant: Only users with Role = 'Participant' can access.

Session-based authentication is used. Upon successful login, the server creates a session cookie that is sent with every subsequent request.

Area 1: Authentication

HTTP method	Route	Description	Role required	Request body	Expected Response
POST	/api/auth/register	Creates a new user account. Accepts email, password, and role selection. Hashes the password before storage. Returns the created user	None (Public)	{ "email": "user@example.com", "password": "SecurePass123!", "role": "Participant" }	201 Created - User object (UserId, Email, Role, CreatedAt). 400 Bad Request - Invalid email format, password too short, or invalid role. 409 Conflict - Email already registered.

		(without password).			
POST	/api/auth/login	Authenticates a user with email and password. Creates a server-side session storing UserId and Role. Returns user info and sets session cookie	None (Public)	{ "email": "user@example.com", "password": "SecurePass123!" }	200 OK - User object with role. Session cookie set. 401 Unauthorized - Invalid credentials. 403 Forbidden - Account disabled (if applicable).
POST	/api/auth/logout	Destroys the current user's session. Clears the session cookie.	Any (Logged In	NONE	204 No Content - Session destroyed successfully. 401 Unauthorized - No active session.
GET	/api/auth/me	Returns the currently authenticated user's basic information from the active session.	Any (Logged In)	NONE	200 OK - { "userId": 1, "email": "user@example.com", "role": "Participant" }. 401 Unauthorized - Not logged in.

Area 2: User Profile

HTTP Method	Route	Description	Role Required	Request Body	Expected Response
GET	/api/profile	Retrieves the currently logged-in user's full	Any (Logged In	None	200 OK - Profile object with related User info.

		profile details including name, phone, date of birth, and profile picture URL.			401 Unauthorized - No active session. 404 Not Found - Profile not yet created.
PUT	/api/profile	Updates the current user's profile information. Only modifies fields provided in the request body.	Any (Logged In)	{ "fullName": "John Updated Doe", "phoneNumber": "0739998888", "dateOfBirth": "1995-11-08" }	200 OK - Updated profile object. 400 Bad Request - Invalid data (e.g., future date of birth). 401 Unauthorized - Not logged in.
PUT	/api/profile/picture	Updates the user's profile picture URL (actual file upload handled by Azure Blob Storage via separate endpoint in Part 3).	Any (Logged In)	{ "profilePictureUrl": "https://raceday.blob.core.windows.net/ profiles/ john-doe.jpg" }	200 OK - Updated profile with new picture URL. 401 Unauthorized - Not logged in

Area 3: Events

HTTP Method	Route	Description	Role Required	Request Body	
GET	/api/ events	Retrieves a list of all upcoming events ordered by event date (ascending). Includes basic event info and organiser name	None (Public	None	200 OK - Array of event objects. Empty array [] if no events exist.
GET	/api/ events/ {id}	Retrieves full details for a specific event including its categories, organiser info, and participant count.	None (Public	None	200 OK - Event object with nested Categories array and EnrolmentCount. 404 Not Found - Event with given ID does not exist.
POST	/api/ events	Creates a new race event. Automatically assigns the logged-in Organiser as the creator. All required fields must be provided.	Organiser	{ "name": "Joburg 10K", "description": "A fast flat 10km race", "eventDate": "2026-09-15T07:00:00", "location": "Ellis Park, Johannesburg", "distanceKM": 10.00, "eventType": "Run" }	201 Created - Event object with generated EventId. 400 Bad Request - Missing required fields or invalid event type. 401 Unauthorized - Not logged in. 403 Forbidden - User is a Participant, not Organiser.
PUT	/api/ events/{id}	Updates an existing event's details. Only the Organiser who created	Organiser	{ "name": "Joburg 10K Updated", "description": "Updated description",	200 OK - Updated event object. 400 Bad Request - Invalid data. 401 Unauthorized -

		the event can modify it. All fields are replaced (full update).		"eventDate": "2026-09-15T07:00:00", "location": "Ellis Park, Johannesburg", "distanceKM": 10.00, "eventType": "Run" }	Not logged in. 403 Forbidden - Not the event owner. 404 Not Found - Event does not exist.
DELETE	/api/ events/ {id}	Removes an event and all its associated categories and enrolments (cascade delete configured in database). Only the owning Organiser can delete.	Organiser	None	204 No Content - Deletion successful. 401 Unauthorized - Not logged in. 403 Forbidden - Not the event owner. 404 Not Found - Event does not exist.
GET	/api/ events/ my	Retrieves all events created by the currently logged-in Organiser. Useful for the Organiser dashboard.	Organiser	None	200 OK - Array of events with enrolment counts. 401 Unauthorized - Not logged in. 403 Forbidden - User is not an Organiser.

Area 4: Categories

HTTP Method	Route	Description	Role Required	Request Body	
GET	/api/ events/ {eventId}/ categories	Lists all categories available for a specific event.	None (Public)	None	200 OK - Array of category objects. 404 Not Found -

		Includes name, description, and age			Event does not exist
POST	/api/ events/ {eventId}/ categories	Adds a new category to an existing event. Only the event' s owning Organiser can add categories.	Organiser	{ "name": "Senior 10km", "description": "For runners aged 35 and above", "minAge": 35, "maxAge": 99 }	201 Created - Category object with generated CategoryId. 400 Bad Request - Invalid age range or missing name. 401 Unauthorized - Not logged in. 403 Forbidden - Not the event owner. 404 Not Found - Event does not exist.
PUT	/api/ categories/ {id}	Updates an existing category's details (name, age range, description). Only the owning Organiser can modify.	Organiser	{ "name": "Senior 10km Updated", "description": "Updated description", "minAge": 35, "maxAge": 99 }	200 OK - Updated category object. 400 Bad Request - Invalid data. 401 Unauthorized - Not logged in. 403 Forbidden - Not the event owner. 404 Not Found - Category does not exist.
DELETE	/api/ categories/ {id}	Removes a category from an event.	Organiser	None	204 No Content - Category

		Fails if participants are already enrolled in this category (to prevent data loss)			deleted. 401 Unauthorized - Not logged in. 403 Forbidden - Not the event owner. 404 Not Found - Category does not exist. 409 Conflict - Cannot delete: participants are enrolled in this category.

Area 5: Event Enrolments

HTTP Method	Route	Description	Role Required	Request Body	
POST	/api/enrolments	Registers the logged-in Participant for an event under a chosen category. The system validates that the category belongs to the selected event and	Participant	{ "eventId": 1, "categoryId": 2 }	201 Created - Enrolment object with EnrolmentId, Status='Confirmed', and EnrolmentDate. 400 Bad Request - Category does not belong to event, or participant does not meet age requirements. 401 Unauthorized - Not logged in. 403 Forbidden - User is an Organiser, not Participant.

		that the participant is not already enrolled.			409 Conflict - Participant already enrolled in this event.
GET	/api/enrolments/my	Retrieves all events the current participant has enrolled in, including event details, category chosen, enrolment status, and result (if available)	Participant	None	200 OK - Array of enrolment objects with nested Event and Category info. 401 Unauthorized - Not logged in. 403 Forbidden - User is not a Participant.
GET	/api/ events/ {eventId}/ enrolments	Lists all participants enrolled in a specific event with their selected categories and enrolment statuses. Only the event's owning Organiser can view.	Organiser	None	200 OK - Array of enrolments with participant names and categories. 401 Unauthorized - Not logged in. 403 Forbidden - Not the event owner. 404 Not Found - Event does not exist.
DELETE	/api/ enrolments/ {id}	Allows a participant to cancel their own	Participant	None	204 No Content - Enrolment cancelled. 401 Unauthorized -

		enrolment before the event date. Removes the enrolment record.			Not logged in. 403 Forbidden - Not the enrolment owner. 404 Not Found - Enrolment does not exist. 409 Conflict - Cannot cancel: event has already taken place

Area 6: Results

HTTP Method	Route	Description	Role Required	Request Body	
POST	/api/ enrolments/ {enrolmentId}/ results	Records the finish time and finishing position for a participant after the event concludes. Only the event's Organiser can capture results.	Organiser	{ "finishTime": "00:45:30", "position": 47	201 Created - Result object with ResultId. 400 Bad Request - Invalid time format or position. 401 Unauthorized - Not logged in. 403 Forbidden - Not the event owner. 404 Not Found - Enrolment does not exist. 409 Conflict - Result already recorded for this enrolment.
GET	/api/ results/ my	Retrieves the current participant's complete	Participant	None}	200 OK - Array of result objects with

		race history across all completed events. Includes event name, date, category, finish time, position, and total finishers (for "X out of Y" display).			event and category details. 401 Unauthorized - Not logged in. 403 Forbidden - User is not a Participant.
GET	/api/ events/ {eventId}/ results	Retrieves all results for a specific event in leaderboard format (sorted by position ascending). Includes participant names, categories, finish times, and positions	Any (Logged In)	None	200 OK - Array of results sorted by position. 401 Unauthorized - Not logged in. 404 Not Found - Event does not exist.
GET	/api/ results/ {id}	Retrieves a single result record by its ID. Useful for detailed result views.	Any (Logged In)	None	200 OK - Result object with full details. 401 Unauthorized - Not logged in. 404 Not Found - Result does not exist.

Summary Table

Area	Endpoints	Total
Authentication	4	4
User Profile	3	7
Events	5	12
Categories	4	16
Event Enrolments	4	20
Results	4	24

Total Planned Endpoints: 24

Design Decisions & Rationale

1. Separate Users and Profiles

A 1:1 relationship separates authentication concerns (email, password, role) from personal details (name, phone, DOB). This follows security best practices and allows profile updates without touching credential data.

2. Enrolments as Junction Entity The many-to-many relationship between Users (Participants) and Events is resolved through the Enrolments table, which also links to Categories. This allows a participant to choose a specific category when entering an event.

3. Results Linked to Enrolments (not Users directly) Results are linked to Enrolments (1:1) rather than directly to Users. This ensures that a result is always tied to a specific event entry with a chosen category, preventing orphaned result records.

4. Role-Based Route Protection All non-public endpoints enforce role checks at the API level. Organiser endpoints verify that the user owns the resource (e.g., only the creator of an event can modify it), preventing unauthorised access even within the same role.

5. Session-Based Authentication Server-side sessions are used instead of JWT tokens to simplify implementation and align with the module requirements. The session stores UserId and Role, which are checked on every protected request.

6. RESTful Naming Convention All routes use plural nouns (events, categories, enrolments) and HTTP methods indicate the action. Nested routes (e.g., /events/{id}/categories) represent parent-child relationships clearly.